

RENCANA UJI KEAMANAN INFORMASI (TESTING PLAN)

IPB SPACE: CAMPUS FACILITY & QUEUE SYSTEM

VALIDASI EMPIRIS INTEGRASI PROTOKOL AAA DAN HARDENING ASPEK KEAMANAN PERANGKAT LUNAK



Disusun Oleh (Kelompok 4 - Paralel 1):

- | | |
|---------------------------|---------------|
| 1. Naufal Ghifari Afdhala | (G6401231029) |
| 2. Samuel Christian | (G6401231037) |
| 3. Muhammad Farhadh | (G6401231080) |

**DEPARTEMEN ILMU KOMPUTER
SEKOLAH SAINS DATA, MATEMATIKA, DAN INFORMATIKA
INSTITUT PERTANIAN BOGOR
BOGOR
2026**

INFORMASI DOKUMEN DAN PARAMETER METADATA REKAYASA UJI

Parameter Pengujian	Spesifikasi Rencana Uji Protokol AAA
Mata Kuliah	KOM1315 Keamanan Informasi (Project-Based Learning Terintegrasi)
Nama Dokumen Luaran	Testing_Plan.pdf (Rencana Uji Integrasi Protokol AAA)
Lokasi Folder Repositori	/02_Design_Documents/Testing_Plan.pdf
Alokasi Output Log Eksekusi	Dipetakan secara transparan pada folder /05_Testing/
Metode Pengujian Utama	Black-Box Functional Security Testing & Integration Unit Testing
Alat Bantu Simulator API	FastAPI TestClient Runtime Engine & Insomnia REST API Client Suite
Target Cakupan Pengujian	Validasi Siklus JWT, Otorisasi RBAC Endpoint Guard, Proteksi Celah IDOR, dan Verifikasi Immutability Log Audit
Kepatuhan Kontrak Kuliah	Pemenuhan Target Integrasi Teknis Milestone Minggu ke-12 Keamanan Informasi

Daftar Isi

BAB 1: PENDAHULUAN	4
1.1 Latar Belakang Rencana Pengujian Keamanan	4
1.2 Tujuan Pengujian Integrasi Protokol AAA	4
1.3 Ruang Lingkup dan Batasan Skenario Uji	4
BAB 2: LINGKUNGAN PENGUJIAN DAN STRATEGI INTEGRASI	6
2.1 Spesifikasi Perangkat Keras dan Perangkat Lunak Pengujian (Testing Environment)	6
2.2 Strategi Integrasi Pengujian Unit pada Alur Utama (Main Workflow Pipeline)	6
2.3 Manajemen Data Uji dan Kredensial Akun Simulasi (Seeding Test Data)	7
BAB 3: MATRIKS SKENARIO PENGUJIAN INTEGRASI PROTOKOL AAA	8
3.1 Skenario Pengujian Fungsi Otentikasi (Authentication Testing - Bearer JWT)	8
3.1.1 Kasus Uji Positif: Login Pengguna via Kredensial Valid	8
3.1.2 Kasus Uji Negatif: Proteksi Kegagalan Login dan Akses Ilegal	8
3.2 Skenario Pengujian Kontrol Akses Berbasis Peran (Authorization Testing - RBAC)	10
3.2.1 Kasus Uji Positif: Hak Akses Fungsional Sesuai Matriks Peran	10
3.2.2 Kasus Uji Negatif: Proteksi Eskalasi Hak Akses dan Simulasi IDOR	10
3.2.3 Pengujian Ketahanan Batas Konkurensi (Concurrency Guard Verification)	11
3.3 Skenario Pengujian Akuntansi Tindakan (Accounting Testing - Immutable Audit Log)	12
3.3.1 Kasus Uji Positif: Otomatisasi Pencatatan Jejak Digital (Audit Trail)	12
3.3.2 Kasus Uji Negatif: Pengujian Immutability Log Basis Data	12
3.4 Skenario Enkripsi dan Proteksi Data Sensitif (Data Protection & Privacy Testing - PROT)	14
BAB 4: KRITERIA KELOLOSAN, EVALUASI, DAN DOKUMENTASI LOG	14
4.1 Kriteria Kelolosan Pengujian (Acceptance Criteria & Expected Results)	14

BAB 1: PENDAHULUAN

1.1 Latar Belakang Rencana Pengujian Keamanan

Implementasi ekosistem digital **IPB Space** sebagai platform terpusat manajemen fasilitas kampus menuntut adanya jaminan keamanan yang menyeluruh pada setiap lapisan arsitektur perangkat lunak yang dibangun. Pengalihan prosedur birokrasi dari pencatatan manual berbasis fisik menjadi transaksi elektronik berbasis web secara otomatis memindahkan seluruh vektor ancaman ke ranah siber. Oleh karena itu, pengujian perangkat lunak tradisional yang hanya berfokus pada validasi kelayakan fungsi bisnis fungsional dianggap tidak lagi memadai untuk memitigasi risiko manipulasi data, kebocoran privasi, maupun eskalasi hak akses ilegal.

Penyusunan rencana pengujian keamanan (**Testing Plan**) ini menjadi langkah krusial untuk mengevaluasi ketangguhan integrasi primitif kriptografi dan kerangka kerja keamanan yang tertanam di dalam kode program aplikasi. Tanpa adanya skenario uji yang terstruktur, celah-celah **edge cases** berbahaya seperti kebocoran data pada kondisi balapan (**race condition**), bypass otorisasi rute API, atau kegagalan penanganan berkas rusak dapat lolos ke tahap produksi dan membahayakan aset informasi institusi. Pengujian ini dirancang secara sistematis untuk mengevaluasi fungsionalitas aplikasi di bawah input yang tidak valid maupun skenario serangan siber yang sengaja disimulasikan untuk menguji ketahanan sistem secara empiris.

1.2 Tujuan Pengujian Integrasi Protokol AAA

Rencana pengujian integrasi protokol AAA (**Authentication, Authorization, Accounting**) pada sistem IPB Space disusun dengan tujuan spesifik sebagai berikut:

1. **Validasi Mekanisme Authentication:** Memastikan fungsionalitas sistem login berbasis OAuth2 dan JSON Web Token (JWT) pada backend FastAPI dapat memverifikasi identitas pengguna secara akurat, mendeteksi token yang tidak sah, serta menangani batasan kedaluwarsa sesi secara tepat.
2. **Validasi Kontrol Authorization:** Menguji efektivitas arsitektur Role-Based Access Control (RBAC) dalam membatasi akses endpoint API sesuai dengan matriks peran fungsional. Pengujian ini bertujuan membuktikan bahwa aktor dengan tingkat privilege rendah (Civitas) secara mutlak diblokir dari eksekusi rute API administratif.
3. **Validasi Akuntabilitas Accounting:** Memverifikasi bahwa setiap operasi administratif krusial memicu pencatatan log otomatis yang aman (**Immutable Audit Trail**) ke database PostgreSQL untuk mengeliminasi celah penyangkalan tindakan (**non-repudiation**).
4. **Pemenuhan Klausul Luaran:** Memenuhi target luaran pengujian teknis Minggu ke-12 sesuai dengan kontrak kuliah mata kuliah Keamanan Informasi IPB University.

1.3 Ruang Lingkup dan Batasan Skenario Uji

Ruang lingkup pelaksanaan pengujian pada dokumen rencana uji ini dibatasi oleh ketentuan teknis sebagai berikut:

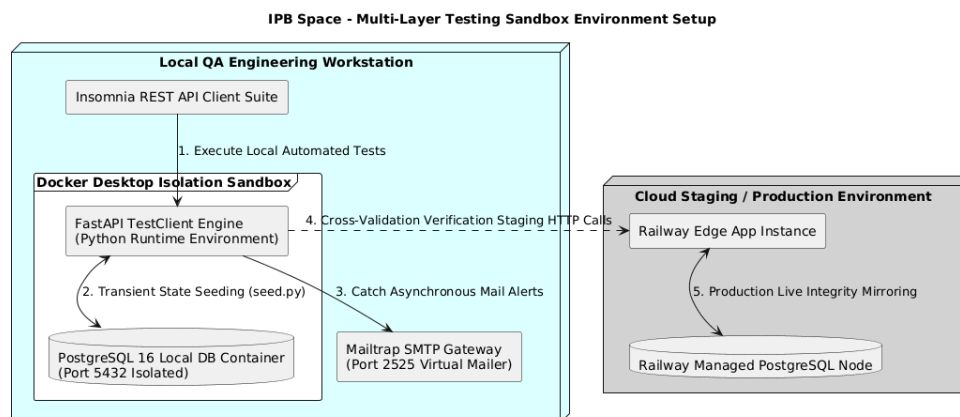
- **Metode Pengujian:** Pengujian difokuskan pada metode **Black-Box Testing** dan **Integration Unit Testing** menggunakan alat bantu FastAPI TestClient serta Insomnia REST API Client Suite untuk menembak langsung rute-rute API backend.
- **Cakupan Skenario:** Pengujian mengeksekusi matriks kasus uji terstruktur yang dikembangkan dari alur kerja nyata aplikasi, meliputi pengujian positif (input valid) dan pengujian negatif (simulasi kesalahan pengguna, pemalsuan data payload, berkas PDF rusak, dan pemboman trafik race condition).

- **Batasan Infrastruktur:** Rencana uji ini hanya mengevaluasi lapis keamanan pada level logika aplikasi (**Application Layer Security**) dan integrasi database relasional. Pengujian tidak mencakup inspeksi keamanan infrastruktur server cloud Railway secara fisik atau pengujian penetrasi jaringan skala luas.

BAB 2: LINGKUNGAN PENGUJIAN DAN STRATEGI INTEGRASI

2.1 Spesifikasi Perangkat Keras dan Perangkat Lunak Pengujian (Testing Environment)

Pelaksanaan pengujian keamanan dikonfigurasi menggunakan dua lapis lingkungan uji, yaitu lingkungan pengembangan lokal (**Local Development**) dan lingkungan pementasan cloud (**Staging Cloud Deployment**), guna menjamin keandalan algoritma secara konsisten:



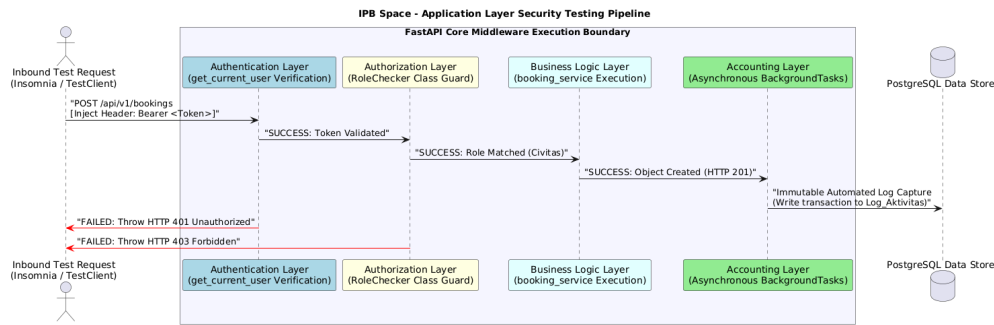
Gambar 2.1: Arsitektur Isolasi Sandbox Lingkungan Pengujian Lokal dan Cloud Staging IPB Space.

Sesuai dengan peta isolasi pada Gambar 2.1, perangkat lunak penunjang rekayasa uji yang wajib dikonfigurasi meliputi:

1. **Insomnia REST API Client Suite:** Media utama simulator untuk menyusun, mengotomatisasi, dan menembak paket payload HTTP/HTTPS menuju rute API backend.
2. **FastAPI TestClient Engine:** Berbasis pustaka httpx untuk melakukan simulasi request unit testing secara asinkron langsung di dalam repositori kode program.
3. **Docker Desktop Sandboxing:** Mengisolasi kluster basis data PostgreSQL lokal agar proses pembersihan data uji tidak merusak integritas data produksi utama.
4. **Mailtrap Sandbox Gateway:** Infrastruktur virtual mailer untuk memverifikasi otomatisasi pengiriman surat elektronik notifikasi status peminjaman ruang.

2.2 Strategi Integrasi Pengujian Unit pada Alur Utama (Main Workflow Pipeline)

Seluruh modul pengujian keamanan tidak dijalankan sebagai skrip terpisah, melainkan menyusup langsung ke dalam pipa dependensi rute utama aplikasi (**Main Workflow Middleware Pipeline**):



Gambar 2.2: Alur Penyusupan Lapis Uji Keamanan pada Middleware Pipeline Backend IPB Space.

Berdasarkan runtunan alur Gambar 2.2, strategi penetrasi pengujian unit dibagi ke dalam tiga lapis perimeter:

- **Penyusupan Lapis Otentikasi:** Menyuntikkan fungsi `get_current_user` dari berkas `app/api/dependencies.py` ke setiap rute API fungsional. TestClient akan mensimulasikan pengiriman header `Authorization: Bearer <token>` untuk memverifikasi kemampuan fungsi pembongkaran klaim JWT.
- **Penyusupan Lapis Otorisasi:** Mengintegrasikan kelas utilitas `RoleChecker` pada tingkat rute pengontrol (**router controller**) untuk menguji batas respon ketika suatu akun dengan peran tertentu mencoba memanggil fungsi di luar hak aksesnya.
- **Penyusupan Lapis Akuntansi:** Ditanamkan langsung pada fungsi manipulasi objek basis data di dalam file `app/services/booking_service.py`. Setiap kali request manipulasi berstatus sukses (HTTP 201 Created), unit uji akan melakukan pengecekan silang (**cross-check database validation**) ke dalam tabel `Log_Aktivitas` untuk memastikan data log audit telah dituliskan secara otomatis detik itu juga.

2.3 Manajemen Data Uji dan Kredensial Akun Simulasi (Seeding Test Data)

Untuk menjalankan skenario otomatis, database PostgreSQL diisi dengan data awal simulasi (**seeding data**) melalui eksekusi berkas backend `seed.py`:

- **Akun Simulasi Peran Civitas:** `user1@ipbspace.com` (Password Plaintext: `User1234` -> Tersimpan sebagai hash Bcrypt). Hanya diizinkan mengeksplorasi fungsi pencarian fasilitas dan pengisian form reservasi personal.
- **Akun Simulasi Peran Facility Admin (Operator):** `admin@ipbspace.com` (Password Plaintext: `Admin1234`). Diizinkan mengeksplorasi rute API peninjauan dokumen, mengubah status menjadi `Approved/Rejected`, serta menyetel status ruangan menjadi `Maintenance`.
- **Akun Simulasi Peran Super Admin (Direktorat DUI IPB):** `manager@ipbspace.com` (Password Plaintext: `Manager1234`). Memiliki hak akses penuh (**Full Privilege**), termasuk mengeksplorasi API penyaringan Audit Log dan perintah darurat `Force Override` jadwal.
- **Master Data Fasilitas:** Ruangan terdaftar “Audit Common Class Room (CCR)” dan “RKU 2.01” dengan status awal `Available` untuk menguji logika batas aman kapasitas dinamis (**safety threshold logic**).

BAB 3: MATRIKS SKENARIO PENGUJIAN INTEGRASI PROTOKOL AAA

Matriks skenario pengujian integrasi ini disusun untuk memverifikasi secara empiris keandalan proteksi lapis keamanan pada sistem informasi IPB Space. Skenario pengujian dibagi secara terstruktur ke dalam tiga domain utama protokol AAA, yakni fungsi Authentication (Otentikasi), Authorization (Otorisasi Peran), dan Accounting (Pencatatan Akuntabilitas), ditambah dengan pengujian enkripsi data privasi. Setiap domain mencakup skenario pengujian positif untuk memvalidasi kesesuaian alur bisnis dan skenario pengujian negatif untuk menguji ketangguhan penanganan kesalahan (*error handling*) sistem di bawah simulasi serangan siber.

3.1 Skenario Pengujian Fungsi Otentikasi (Authentication Testing - Bearer JWT)

Pengujian fungsi otentikasi difokuskan pada pengujian gerbang masuk sistem informasi untuk memastikan bahwa hanya pengguna dengan identitas valid yang dapat memperoleh token akses JSON Web Token (JWT) secara sah.

3.1.1 Kasus Uji Positif: Login Pengguna via Kredensial Valid

Memastikan server backend FastAPI dapat memverifikasi kecocokan data password hash di database dan mengembalikan Bearer Token yang sah ke sisi klien.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_AUT_01_001	Civitas Auth	1. Akses halaman login IPB Space. 2. Masukkan email user1@ipbspace.com. 3. Masukkan password User1234. 4. Klik tombol "Masuk".	Sistem berhasil memverifikasi kredensial, mengembalikan token JWT, dan mengarahkan pengguna ke halaman Dashboard Civitas.
TC_AUT_01_002	Admin Auth	1. Akses halaman login. 2. Masukkan email admin unit admin@ipbspace.com. 3. Masukkan password Admin1234. 4. Klik tombol "Masuk".	Sistem berhasil memverifikasi data, mengembalikan token JWT administratif, dan membuka gerbang Dashboard Operator.

3.1.2 Kasus Uji Negatif: Proteksi Kegagalan Login dan Akses Ilegal

Skenario ini menguji respons sistem dalam menolak percobaan masuk yang tidak sah demi melindungi database dari ancaman **brute force** dan **credential stuffing**.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_AUT_02_001	Auth Exception	1. Akses halaman login. 2. Masukkan email	Sistem menolak autentikasi, memblokir pembuatan token

	user1@ipbspace.com. 3. Masukkan password salah WrongPass123. 4. Klik “Masuk”.	JWT, dan memunculkan pesan kesalahan “Kredensial tidak valid” (HTTP 401).
TC_AUT_02_002Auth Exception	1. Akses rute login. 2. Kosongkan kolom input email dan kata sandi. 3. Klik tombol “Masuk”.	Sistem memblokir request di sisi frontend dan memunculkan notifikasi validasi “Semua kolom wajib diisi” (HTTP 422 Strict Error).
TC_AUT_02_003Auth Exception	1. Simulasikan serangan brute force dengan menembak request gagal 5 kali berturut-turut pada rute login.	Sistem mengaktifkan Account Lockout Policy, mengubah flag <code>is_locked</code> menjadi true, dan membekukan akun selama 15 menit (HTTP 423 Locked).

3.2 Skenario Pengujian Kontrol Akses Berbasis Peran (Authorization Testing - RBAC)

Pengujian otorisasi bertujuan untuk memastikan bahwa implementasi **Role-Based Access Control** (RBAC) pada middleware FastAPI bekerja secara presisi dalam mengisolasi wewenang operasional antar-peran serta memitigasi kerentanan **Insecure Direct Object Reference** (IDOR).

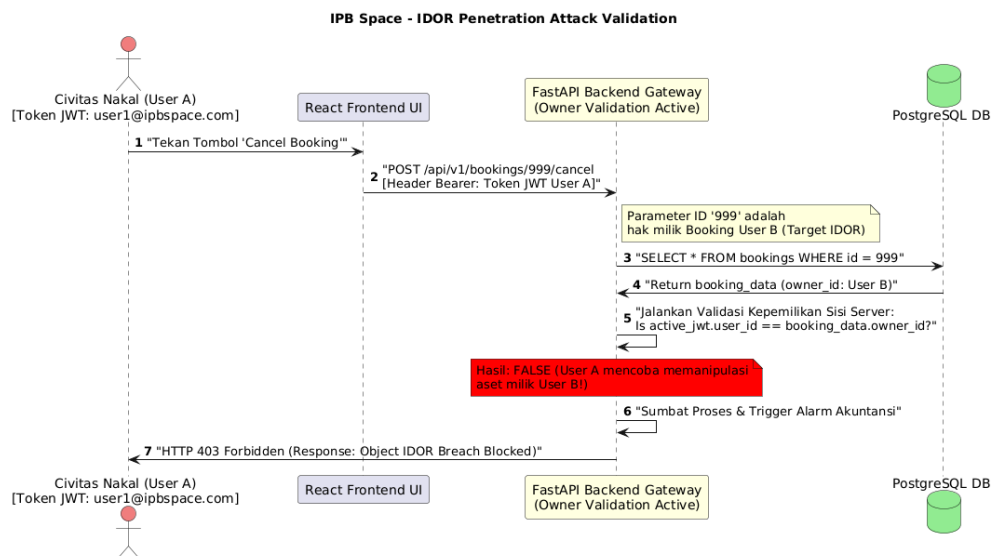
3.2.1 Kasus Uji Positif: Hak Akses Fungsional Sesuai Matriks Peran

Memastikan setiap aktor dapat mengeksekusi endpoint fungsional yang memang menjadi hak akses resminya di dalam sistem.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_ATH_01_001	Civitas Access	1. Login sebagai civitas. 2. Isi form reservasi ruangan Audit CCR secara valid. 3. Unggah proposal PDF. 4. Klik kirim.	Sistem menerima request, mengunci transaksi (HTTP 201 Created), menyimpan record dengan status Pending, dan mengirim notifikasi email.
TC_ATH_01_002	Operator Access	1. Login sebagai operator (admin@ipbpace.com). 2. Buka daftar permohonan pending. 3. Klik aksi persetujuan (Approve).	Sistem memperbarui status data di database, mengunci jadwal kalender, dan menerbitkan tiket digital terenkripsi (HTTP 200 OK).

3.2.2 Kasus Uji Negatif: Proteksi Eskalasi Hak Akses dan Simulasi IDOR

Skenario vital Keamanan Informasi untuk menguji keandalan **server-side validation** ketika ada aktor luar atau pengguna biasa yang mencoba memanipulasi parameter token ataupun menembak API administratif secara ilegal.

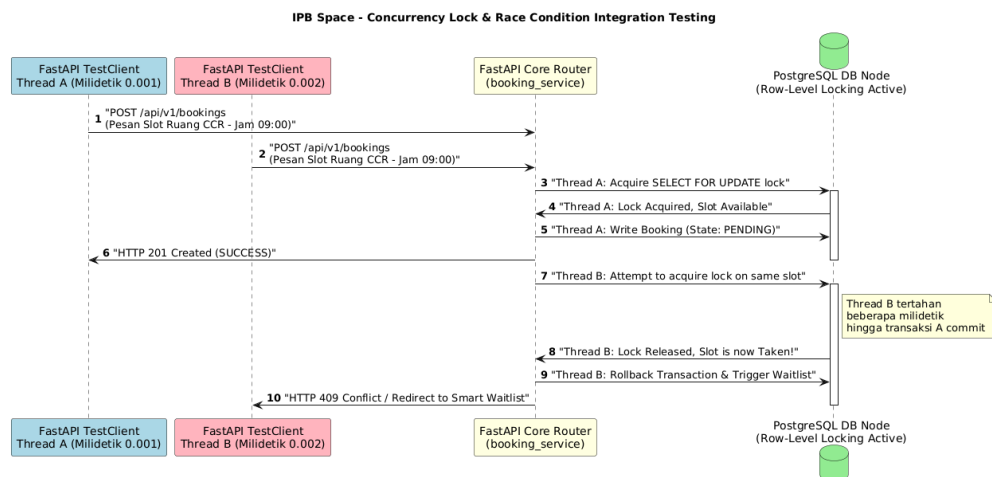


Gambar 3.1: Alur Pemutusan Serangan Penetrasi IDOR oleh Server-Side Owner Validation.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_ATH_02_001	Privilege Escalation	1. Login menggunakan akun civitas. 2. Gunakan Insomnia Client untuk menembak langsung rute API administratif pembatalan darurat Super Admin.	Middleware backend FastAPI melalui <code>ensure_is_admin</code> mendeteksi ketidaksesuaian peran, memblokir proses, dan mengembalikan status 403 Forbidden.
TC_ATH_02_002	IDOR Tampering	1. Jalankan pengujian skenario Gambar 3.1. 2. Akun Civitas A menembak parameter ID booking milik Civitas B ke rute pembatalan / <code>cancel_booking</code>.	Fungsi Owner Validation mendeteksi klaim <code>user_id</code> token tidak cocok dengan pemilik record asli di DB, menggagalkan mutasi, dan melempar error 403 Forbidden.

3.2.3 Pengujian Ketahanan Batas Konkurensi (Concurrency Guard Verification)

Sistem diuji menggunakan simulator **FastAPI TestClient** untuk menembakkan dua request reservasi secara simultan pada slot waktu milidetik yang sama guna membuktikan hilangnya celah **Phantom Booking**:

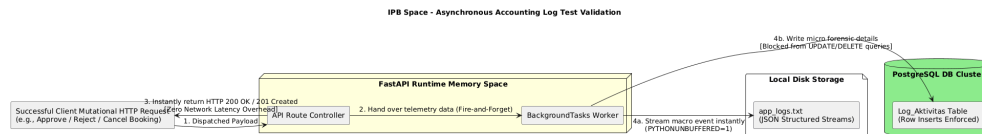


Gambar 3.2: Runtunan Penanganan Kondisi Balapan (Race Condition) Melalui Database Lock.

Sesuai urutan Gambar 3.2, kasus uji dinyatakan lolos jika dan hanya jika Thread A yang masuk dalam hitungan milidetik terkecil berhasil mengunci baris database relasional (**Row-Level Lock Obtained**), sedangkan Thread B secara aman langsung dimentahkan oleh sistem dengan kode respons HTTP 409 Conflict dan dialirkan masuk ke dalam antrean **Smart Waitlist** berbasis logika antrean FIFO.

3.3 Skenario Pengujian Akuntansi Tindakan (Accounting Testing - Immutable Audit Log)

Pengujian domain **Accounting** dilakukan untuk memverifikasi secara empiris bahwa sistem secara otomatis menangkap jejak digital dari setiap tindakan kritis dan melindunginya secara absolut dari manipulasi riwayat ataupun penghapusan jejak oleh oknum internal melalui pipa pemrosesan asinkron:



Gambar 3.3: Mekanisme Verifikasi Pipa Pengujian Akuntansi Asinkron (BackgroundTasks).

3.3.1 Kasus Uji Positif: Otomatisasi Pencatatan Jejak Digital (Audit Trail)

Memastikan bahwa setiap klik keputusan krusial oleh operator atau pengguna meluncurkan penulisan log relasional secara *real-time* sesuai skema Gambar 3.3.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_ACC_01_001	Logging Trigger	- Login sebagai Facility Admin. - Tolak satu berkas pending dengan memasukkan alasan “Dokumen Tidak Sah”. - Periksa kueri tabel database.	Status permohonan berubah menjadi Rejected dan baris log baru (ID Admin, Aksi: REJECT, Timestamp) otomatis tertulis secara asinkron di database PostgreSQL.
TC_ACC_01_002	Logging Trigger	- Login sebagai Super Admin. - Eksekusi fungsi Force Cancel pada satu jadwal aktif. - Jalankan pengecekan UUID request_id lintas file log.	Jadwal dibatalkan sepihak, slot dikosongkan, dan data log tindakan darurat terekam permanen dengan UUID request_id yang sinkron lintas layer (HTTP 200 OK).

3.3.2 Kasus Uji Negatif: Pengujian Immutability Log Basis Data

Pengujian destruktif untuk membuktikan pemenuhan klausa **Immutable Audit Trail**, di mana data yang sudah masuk tidak boleh bisa diubah atau dihapus oleh pihak pengelola harian.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_ACC_02_001	Log Protection	- Login menggunakan akun Facility Admin. - Gunakan konsol kueri	Sistem dan database mesin secara mutlak menolak perintah modifikasi/

SQL / REST API suite untuk memaksakan kueri DELETE FROM login_logs.	penghapusan, memicu database integrity exception, dan menjamin data log tetap utuh.
---	---

3.4 Skenario Enkripsi dan Proteksi Data Sensitif (Data Protection & Privacy Testing - PROT)

Skenario pengujian ini difokuskan untuk memvalidasi performa algoritma kriptografi simetris di level kolom dan keandalan gerbang **MIME-Type Validation** backend dalam menyaring unggahan file berbahaya.

ID Kasus Uji	Komponen Fitur	Langkah-Langkah Pengujian	Kriteria Kelolosan (Expected Result)
TC_PRT_01_001	Column Crypto	1. Akses baris data pada tabel database users melalui terminal admin PostgreSQL.	Kolom data sensitif NIM/NIP, NIK, dan Nomor HP terbukti tersimpan dalam format acak teks tersandi (Ciphertext Base64 256-bit), bukan plaintext.
TC_PRT_01_002	API Exposure	1. Tembak request kueri GET rute /api/v1/users/me. 2. Periksa manifest data respons JSON.	Data profil dikembalikan lengkap, namun kolom password hash dan metadata kunci rahasia secara ketat di-filter (tidak ikut keluar ke klien).
TC_PRT_01_003	File Upload Filter	1. Akses formulir reservasi ruang. 2. Unggah file skrip berbahaya bernama exploit.sh sebagai dokumen proposal. 3. Klik kirim.	Sistem backend mendeteksi ketidaksesuaian tipe berkas melalui deep checking, menolak request secara mutlak, dan mengembalikan status HTTP 400 Bad Request.
TC_PRT_01_004	MIME Spoofing	1. Siapkan file backdoor PHP. 2. Ubah ekstensinya menjadi photo.png (Masquerade attack). 3. Unggah ke sistem.	Validasi biner MIME-type backend FastAPI berhasil mengidentifikasi bahwa muatan asli berkas adalah skrip ilegal, lalu memblokir unggahan (HTTP 400).

BAB 4: KRITERIA KELOLOSAN, EVALUASI, DAN DOKUMENTASI LOG

4.1 Kriteria Kelolosan Pengujian (Acceptance Criteria & Expected Results)

Untuk menentukan keberhasilan integrasi lapis keamanan pada sistem informasi IPB Space, ditetapkan sebuah standar acuan evaluasi yang ketat terhadap hasil eksekusi setiap kasus uji:

- **Kriteria Kelolosan Fungsi Otentikasi (Authentication):** Pengguna yang memasukkan kombinasi email dan kata sandi yang valid wajib menerima respon kode status HTTP 200 OK, diikuti dengan pengembalian payload JSON yang memuat objek access_token berbasis JWT. Setiap percobaan masuk menggunakan kredensial yang salah, wajib digagalkan secara mutlak pada level gateway

controller dengan mengembalikan kode status HTTP 401 Unauthorized tanpa toleransi kebocoran sesi.

- **Kriteria Kelolosan Fungsi Otorisasi (Authorization):** Aktor hanya diizinkan mendapatkan respon sukses ketika mengeksekusi endpoint REST API yang sesuai dengan hak aksesnya di dalam sistem. Ketika aktor dengan peran tingkat rendah (Civitas) mencoba menembak rute API administratif khusus peran tinggi (Super Admin), middleware otorisasi pada backend FastAPI harus memotong alur instruksi sebelum menyentuh logika bisnis dan mengembalikan respon kode status HTTP 403 Forbidden secara konsisten.
- **Kriteria Kelolosan Fungsi Akuntansi & Proteksi (Accounting & Protection):** Setiap kali operasi modifikasi data kritis menghasilkan kode status sukses, sistem wajib memicu background task untuk menuliskan baris log baru ke database PostgreSQL secara asinkron. Berkas .env rahasia terbukti tidak terdapat dalam riwayat commit repositori git, serta kueri manipulasi SQL Injection terbukti lumpuh total melalui implementasi parameterized queries ORM SQLAlchemy dengan mengembalikan hasil kosong (HTTP 200/401) tanpa merusak integritas basis data.